

Information Security and Privacy Policy

Policy Owner: Information Security and Privacy

Effective Date: January 1, 2026

Applies To: All employees, contractors, and temporary workers

1. Purpose

The company develops and operates healthcare technology products and handles confidential company information, customer information, and, in certain circumstances, protected health information (PHI).

Employees are responsible for protecting information against unauthorized access, disclosure, alteration, or loss.

2. Access to Company Systems

Employees may access company systems only using their assigned accounts.

Employees must not:

- Share passwords or authentication tokens.
- Use another employee's credentials.
- Circumvent access controls.
- Access information unrelated to their job responsibilities.

Access must follow the principle of least privilege.

3. Protected Health Information

Employees who have access to PHI must handle it only for authorized business purposes.

PHI must not be copied to personal devices, personal cloud storage, or unauthorized applications.

Employees must not enter PHI into publicly available generative-AI services unless the service has been explicitly approved by Information Security and Privacy.

4. Generative AI

Employees may use company-approved AI tools for business purposes.

Confidential company information, customer information, PHI, credentials, and other restricted data may only be submitted to AI systems explicitly approved for that data classification.

Employees are responsible for reviewing AI-generated content before using it in business decisions or customer-facing materials.

5. Devices and Networks

Company systems must be accessed using company-managed devices when required by the employee's role.

Employees working remotely must use approved secure network connections.

Public Wi-Fi should not be used for sensitive activities unless an approved company security control is active.

6. Security Incidents

Employees must promptly report suspected:

- Unauthorized access.
- Lost or stolen devices.
- Phishing attacks.
- Accidental disclosure of confidential information.
- Exposure of credentials.
- Unauthorized disclosure of PHI.

Security incidents should be reported to the Security Operations team through the company's incident reporting channel.

7. Data Retention

Employees must retain company information only for as long as required for legitimate business purposes and applicable retention requirements.

Employees must not create unauthorized copies of sensitive information for convenience.

8. Third-Party Services

Employees must not connect company data to third-party applications or services without appropriate company approval.

This includes SaaS applications, AI services, browser extensions, data-processing tools, and file-sharing services.

9. Questions

Questions regarding information classification, PHI, AI tools, or security requirements should be directed to Information Security or the Privacy team.